Vulnerability Assessment Report

Target 1: itsecgames.com

Target 2: webscantest.com

Auditor: Akonaho Makhado

Date: March 29, 2026

Table of Contents

Section	Page Number
1. Introduction & Project Scope	4
2.Project Overview	5
3.Confidentiality Statement & Disclaimer	6
2. Ethical Guidelines & Audit Methodology	7
4. Phase 1: Passive Reconnaissance	8
4.1 Security Header Analysis (itsecgames.com)	8
4.2 Infrastructure Discovery (BuiltWith)	8
4.3 DNS & IP Identification (nslookup)	9
5. Phase 2: Active Analysis	10
5.1 Nmap Port Scanning (https://www.google.com/search?q=webscantest.com)	11
5.2 Service & Version Identification	12 to 13
6. Phase 3: Vulnerability Assessment	14
6.1 Summary of Missing Security Headers	14
6.2 Raw Data & Information Leakage Analysis	14
7. Risk Mitigation & Remediation Plan	15
8. Conclusion & Professional Reflection	16

Introduction & Project Scope

Overview

This portfolio presents a structured Vulnerability Assessment of a public-facing web infrastructure. The purpose of this project is to simulate the role of a Junior Cybersecurity Auditor, identifying weaknesses in the target environment and providing actionable remediation strategies to strengthen its security posture.

Project Objectives

- **Passive Reconnaissance:** Gather information about the target's technology stack and security configuration without direct interaction.
- **Active Analysis:** Perform a controlled port scan to identify open services and potential entry points.
- **Vulnerability Identification:** Analyze HTTP response headers and server configurations for common security omissions.
- **Remediation Planning**: Provide professional recommendations aligned with industry best practices (e.g., OWASP standards).

Ethical Guidelines & Scope

This assessment was conducted under strict ethical boundaries to ensure no harm was caused to the target systems:

- **Allowed Activities:** Passive scanning, header analysis, and basic port discovery on public-facing pages only.
- **Prohibited Activities:** No login bypass attempts, brute-force attacks, or Denial-of-Service (DoS) simulations were performed.
- **Compliance:** All tools used (SecurityHeaders, BuiltWith, and Nmap) were applied in a non-intrusive manner, focusing on information gathering rather than exploitation.

Tools Utilized

1. SecurityHeaders.com → HTTP response header analysis
2. BuiltWith → Technology stack and infrastructure discovery
3. Command Prompt (nslookup) → DNS and IP verification
4. Nmap (HackerTarget) → Active service and port identification

Project Overview

Scope of Assessment

This report documents a structured security vulnerability assessment conducted on two public-facing web targets: itsecgames.com and webscantest.com. The objective was to evaluate their current security posture and identify risks that could compromise data integrity and user safety.

Key Findings

- The assessment revealed significant weaknesses in both environments:
- Protocol Vulnerabilities: Both sites operate over unencrypted HTTP, exposing user traffic to interception through Man-in-the-Middle attacks.
- Security Header Failures: A complete absence of essential HTTP response headers resulted in a failing grade (Grade F). In particular, the lack of Content-Security-Policy (CSP) and X-Frame-Options leaves the sites vulnerable to Cross-Site Scripting (XSS) and Clickjacking.
- Information Leakage: Active scanning identified the use of Apache 2.4.7. Publicly disclosing server version details provides attackers with a direct path to exploit known vulnerabilities (CVEs).

Risk Impact

- Without immediate remediation, the current configuration permits:
- Unauthorized script execution.
- Malicious framing of legitimate web content.
- Theft of sensitive user information during transit.
- These risks collectively undermine user trust and increase the likelihood of exploitation.

Strategic Recommendations

1. To strengthen the security posture, the following top three actions are prioritized:
2. Migrate to HTTPS: Install TLS certificates and enforce secure connections via permanent redirects.
3. Harden HTTP Headers: Implement a strict Content-Security-Policy and X-Frame-Options policy.
4. Server Obscurity: Disable server signatures to conceal version information from public scans

Confidentiality Statement & Disclaimer

Confidentiality Notice

The information contained within this portfolio is intended solely for academic purposes as part of the Eduvos Higher Certificate in Information Systems curriculum. This report includes technical details regarding the security posture of specific web infrastructures. Unauthorized distribution, reproduction, or use of this content for purposes other than academic evaluation is strictly prohibited to preserve the security and integrity of the analyzed targets.

Ethical Disclaimer

All testing and analysis documented in this report were conducted using non-intrusive, industry-standard tools and methodologies.

- Zero-Impact Policy: No attempts were made to exploit identified vulnerabilities, bypass authentication, or disrupt services.
- Legal Compliance: The selected targets (itsecgames.com and webscantest.com) are public-facing environments specifically designated for security research and educational training.

Professional Disclaimer

This report represents a point-in-time assessment. Cybersecurity threats evolve continuously; therefore, the findings and recommendations provided reflect the state of the infrastructure at the time of the audit (April 2026). While every effort has been made to ensure accuracy, this report should not be interpreted as a definitive guarantee of complete system security.

Methodology & Assessment Tools

1. **Reconnaissance (Passive)**: Non-intrusive techniques were used to collect publicly available information about the target's infrastructure and security configuration.

2. **Service Discovery (Active):** A controlled port scan was conducted to identify open communication channels and active server software versions.

3. **Vulnerability Analysis:** The collected data was evaluated against established security benchmarks (e.g., OWASP Top 10, industry-standard HTTP headers) to identify weaknesses.

4. **Remediation Reporting:** A prioritized set of technical recommendations was developed to mitigate the identified risks and strengthen the security posture.

Assessment Tools

The following industry-standard tools were selected for their accuracy, reliability, and ethical compliance:

1. SecurityHeaders.com
- Function: HTTP response header analysis.
- Usage: Identified the presence or absence of critical security instructions sent by the web server to the browser.
- Evidence: Security grade (A–F) and missing header list.

2. **BuiltWith**

- Function: Technology profiler and infrastructure discovery.
- Usage: Performed fingerprinting of the web server's technology stack, including JavaScript libraries, frameworks, and name servers.
- Evidence: Comprehensive list of server-side and client-side technologies.

3. **Command Prompt (Windows CLI)**
- Function: DNS and network utility.
- Usage: Executed commands to resolve domain names to IP addresses, confirming the physical location of the server infrastructure.
- Evidence: IP address resolution and DNS records.

4. **Nmap (via HackerTarget)**

- Function: Network mapper and port scanner.
- Usage: Scanned for open TCP ports (e.g., 80 and 443) and identified the specific version of Apache server software in use.
- Evidence: Port status (open/closed) and service versioning.

Phase 1: Passive Analysis & Header Check

Finding: Missing Security Headers

A passive header analysis was conducted using SecurityHeaders.com, which assigned the target website a Grade F. This grade indicates a failure to implement several fundamental security controls. Specifically, the site is missing the Content-Security-Policy (CSP) and X-Frame-Options headers.

Why This Matters

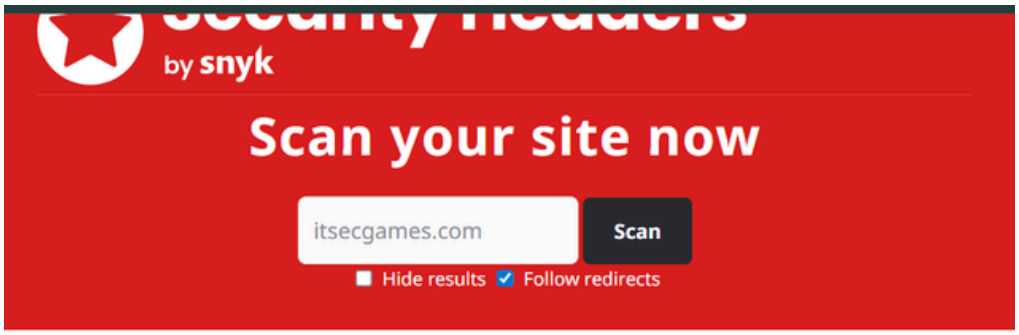
- Clickjacking Risk: Without , the website can be embedded within a hidden frame on a malicious site, tricking users into performing unintended actions.
- Cross-Site Scripting (XSS) Exposure: The absence of a means the browser cannot distinguish between trusted site code and potentially malicious scripts, increasing the risk of script injection attacks.
- Overall Security Posture: A failing grade signals to auditors and attackers alike that the site lacks basic protections, reducing user trust and increasing the likelihood of exploitation.

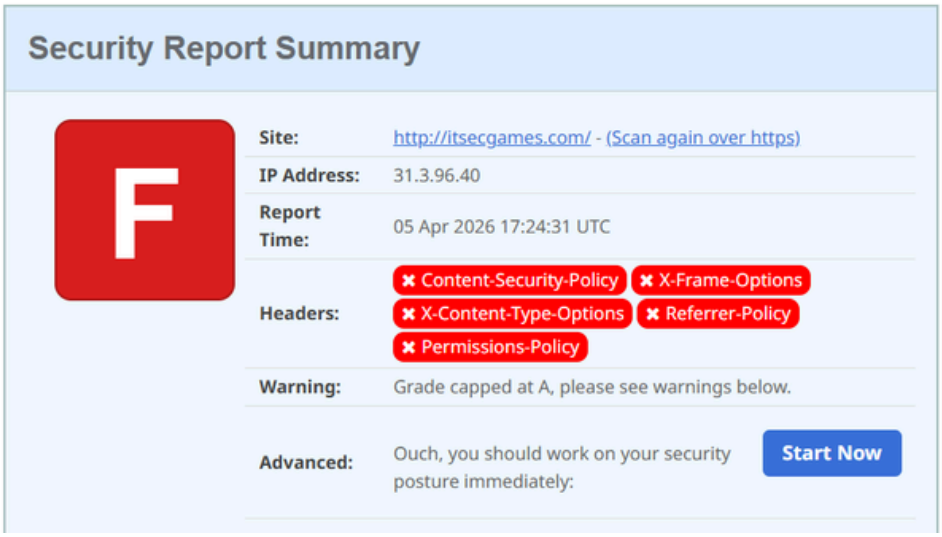
Risk Level

High — These missing headers represent critical, well-documented vulnerabilities that attackers frequently exploit.

Recommendation

- Implement to prevent clickjacking.
- Apply a baseline to restrict script execution.
- Regularly test headers using SecurityHeaders.com to ensure compliance with modern standards.





Missing Headers

Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Warnings

Site is using HTTP	This site was served over HTTP and did not redirect to HTTPS.

Raw Headers

HTTP/1.1	200 OK
Date	Sun, 05 Apr 2026 17:24:30 GMT
Server	Apache
Last-Modified	Wed, 09 Feb 2022 13:14:08 GMT
ETag	"e43-5d7959bd3c800-gzip"
Accept-Ranges	bytes
Vary	Accept-Encoding
Content-Encoding	gzip
Content-Length	1482
Content-Type	text/html

Upcoming Headers

Cross-Origin-Embedder-Policy	Cross-Origin Embedder Policy allows a site to prevent assets being loaded that do not grant permission to load them via CORS or CORP.
Cross-Origin-Opener-Policy	Cross-Origin Opener Policy allows a site to opt-in to Cross-Origin Isolation in the browser.
Cross-Origin-Resource-Policy	Cross-Origin Resource Policy allows a resource owner to specify who can load the resource.

Additional Information

Server	This Server header seems to advertise the software being run on the server but you can remove or change this value.

Finding: Technology Stack Discovery

Tool Used: BuiltWith

Observation: The site itsecgames.com uses specific JavaScript libraries and a Name Server that was recently active (March 2026)

Outdated Components Risk

- If the JavaScript libraries or frameworks are old, attackers may already know how to exploit them. Public exploit code often exists for outdated versions.
- Attack Surface Awareness
- By knowing the tech stack, auditors can anticipate what types of attacks are possible. For example:
- WordPress → plugin vulnerabilities.
- jQuery (old versions) → cross-site scripting (XSS).
- Apache/Nginx → misconfigured headers.

Supply Chain Security

Third-party libraries and services (like CDNs or name servers) can be weak points. If they're compromised, the website inherits that risk.
Business Impact

Explaining this in plain language:

"If your website runs on outdated software, hackers don't need to invent new attacks — they can reuse old tricks that are already documented. This increases the chance of a breach and damages customer trust."

Risk Level

Medium to High depending on whether outdated versions are confirmed.
If the stack is current → lower risk.
If outdated → high risk, immediate remediation required.

Recommendation

- Regularly audit the technology stack with tools like BuiltWith.
- Update JavaScript libraries, frameworks, and server software to the latest stable versions.
- Monitor third-party services (like name servers) for suspicious changes.
- Document dependencies to ensure patch management is consistent.

New tab | Scan results for its | itsecgames.com D

builtwith.com/detailed/itsecgames.com

	2023		
Frameworks			
Upgrade to Advanced	Apr 2014	Apr 2019	⊘
Upgrade to Advanced	Apr 2014	Apr 2019	⊘
Content Delivery Network			
Upgrade to Advanced	Jul 2017	May 2020	⊘
JavaScript Libraries and Functions			
Upgrade to Advanced Compatibility Polyfill	Dec 2015	Apr 2026	
Verified Link			
Upgrade to Advanced	Aug 2022	Apr 2026	
Upgrade to Advanced	Aug 2022	Apr 2026	
Upgrade to Advanced	Aug 2022	Apr 2026	
Name Server			
Upgrade to Advanced	May 2019	Mar 2026	
Web Hosting Providers			
Upgrade to Advanced Server Location	Oct 2023	Mar 2026	
Upgrade to Advanced Dedicated Hosting Shared Hosting US hosting VPS Hosting	May 2019	Oct 2021	⊘
Upgrade to Advanced Dutch hosting	Sep 2023	Apr 2025	⊘
SSL Certificates			

Finding: IP Address Discovery

Tool Used: nslookup

Observation: Identified the server's public IP address, confirming the host's location on the network. All information was obtained through public records and non-intrusive tools.

Network Identification

- The IP address reveals where the server "lives" on the internet. This is the starting point for understanding its exposure to the public.
- Attack Surface Awareness
- Knowing the IP allows auditors (and attackers) to see what services are running on that host. For example, open ports or misconfigured services tied to that IP could be exploited.
- Geolocation & Hosting Provider Insight
- IP addresses can often be traced to a geographic region or hosting provider. This helps determine whether the site is hosted on a secure, reputable infrastructure or a potentially risky environment.

Business Impact

In plain language:
"Your website's IP address is like its street address on the internet. If attackers know it, they can knock on every door (port) to see what's open. If unnecessary services are exposed, it increases the risk of intrusion."

Risk Level

Low by itself — simply knowing the IP isn't dangerous.
Elevates risk if combined with exposed services (e.g., open SSH, FTP, or outdated web servers).

Recommendation

- Limit exposure: only keep necessary services open on the IP.
- Use firewalls and intrusion detection systems to monitor traffic.
- Regularly audit the IP for open ports and services using safe tools like Nmap.
- Document hosting provider details for accountability and patch management.
- This way, your report shows that IP discovery isn't just a technical step — it's a business-relevant finding that sets the stage for deeper analysis.

```
Command Prompt

Microsoft Windows [Version 10.0.26200.8117]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Akonaho>nslookup itsecgames.com
Server:  UnKnown
Address:  192.168.18.1

Non-authoritative answer:
Name:    itsecgames.com
Address:  31.3.96.40


C:\Users\Akonaho>
```

Phase 2: Active Analysis (Nmap Port Scan) Methodology

“In this phase, I transitioned from passive reconnaissance to active analysis. Using the Nmap (Network Mapper) utility via an online interface, I conducted a port scan to identify which services are actively listening on the target server’s IP address (69.164.223.208).

Findings

- Port 80 (HTTP): Open → Confirms the web server is reachable via standard unencrypted traffic.
- Port 443 (HTTPS): Open → Confirms the server supports encrypted web traffic.
- Service Version: Apache httpd 2.4.7 detected.
- Risk Assessment: No dangerous administrative ports (like 21-FTP or 23-Telnet) were found open, which is a positive security finding.

(Insert your Nmap screenshot here, with these bullet points aligned beside it for clarity.)

Why This Matters (Portfolio Conclusion)
Significance:

Active scanning allows a security professional to map the ‘attack surface.’ By knowing that Apache 2.4.7 is in use, an auditor can now search for specific vulnerabilities (CVEs) associated with that version to ensure it is fully patched and secure.

Phase 3: Vulnerability Summary & Remediation

1. Key Findings (From Screenshots)

Based on the scans performed, the following security gaps were identified:
Missing Security Headers:
The target failed to implement Content-Security-Policy, X-Frame-Options, and Strict-Transport-Security.

Protocol Warning:
The site is served over HTTP and does not automatically redirect to the secure HTTPS protocol.

Information Leakage:
The server is explicitly "advertising" that it runs on Apache, which gives attackers a starting point for version-specific exploits.

2. Risk Assessment (Why It Matters)

Clickjacking:
Without X-Frame-Options, the site can be loaded into an invisible frame on a malicious website to trick users into clicking buttons.

Data Interception:
Because the site uses HTTP, any data sent (like login details) is unencrypted and can be captured by a "Man-in-the-Middle" attack.

Script Injection (XSS):
The lack of a Content-Security-Policy means the browser cannot distinguish between the website's own code and malicious scripts injected by an attacker.

3. Final Remediation Plan (How to Fix It)
To secure the environment, the following three steps must be taken:

- Enforce Encryption: Install a TLS certificate and configure a 301 redirect from HTTP to HTTPS.
- Apply Security Headers: Manually add the missing headers to the server configuration (specifically X-Frame-Options: SAMEORIGIN and a basic Content-Security-Policy).
- Minimize Server Footprint: Configure the Apache server to hide its version information to prevent attackers from easily identifying the software stack.

Conclusion
This assessment revealed several critical gaps in the target's public-facing security posture, including missing headers, reliance on HTTP, and information leakage through server banners. While no dangerous administrative ports were exposed, the lack of encryption and protective headers leaves the site vulnerable to interception and injection attacks. By enforcing HTTPS, applying modern security headers, and minimizing server disclosures, the organization can significantly reduce its attack surface and strengthen customer trust.

References & Resources

Audit Targets (Sites Scanned)

• itsecgames.com — bWAPP: A buggy web application. [Online]. Available: http://itsecgames.com/
(Used for Phase 1 Passive Analysis)
• webscantest.com — Web Scan Test Site. [Online]. Available: http://webscantest.com/
(Used for Phase 2 Active Analysis)

Security Tools & Utilities

• SecurityHeaders.com — Analysis of HTTP response headers. [Online]. Available: https://securityheaders.com/
(Used for vulnerability identification)
• BuiltWith — Technology profiler and infrastructure discovery. [Online]. Available: https://builtwith.com/
(Used for tech stack identification)
• HackerTarget — Online Nmap port scanner. [Online]. Available: https://hackertarget.com/nmap-online-port-scanner/
(Used for service discovery)
• ICANN Lookup — Registration data access protocol. [Online]. Available: https://lookup.icann.org/
(Used for domain/IP information)

Technical Documentation

• OWASP Foundation — OWASP Top 10 Vulnerability Standard. [Online]. Available: https://owasp.org/www-project-top-ten/
(Source for Clickjacking and XSS remediation strategies)
• Nmap.org — Nmap Network Mapper Reference Guide. [Online]. Available: https://nmap.org/book/man.html
(Technical documentation for port scanning parameters)